

IDS/IPS: Suricata, Rules, Deployments

NIDS vs HIDS

Type	Sees	Blindspots
NIDS (network)	All wire traffic	Encrypted payloads, if no TLS break; spans
HIDS (host)	Process/file/reg events	Its own visibility limits; agent cost

Suricata: the modern NIDS/NIPS

```
# install + run IDS mode (suricata in Kali/lab)
sudo apt install -y suricata
sudo suricata -c /etc/suricata/suricata.yaml -i eth0
cat /var/log/suricata/fast.log

# check rules loaded:
suricatasc -c 'list rules' | head

# run IPS (inline NFQUEUE) requiring 2 NICs or a bridge:
sudo suricata --af-packet -q 0 -q 1 -c /etc/suricata/suricata.yaml
```

Rule anatomy (ET/open rulesets)

```
alert tcp $HOME_NET any -> $EXTERNAL_NET 443 (msg:"POST to EURL"; flow:established,to_server; content:"|00 00 00|"; c
```

Deployment & tuning reality

- Rules fire on *conditions*, not judgment → FPs inevitable
- Tune per alert: suppress by source/dest, or mark as alert→log only
- Sig-updates: ET open rules daily; commercial weekly

IPS (inline) risks: can't drop legit traffic → test in IDS mode first, start with 'alert, then drop'

Correlate: an IDS alert is a *trigger*, not a verdict – pair with endpoint logs

The analyst workflow

```
alert -> validate in matching pcaps -> correlate host events -> decide/bloom  
      -> if true positive: IR handoff; else suppress + document
```

A well-tuned IDS is a tripwire farm: alerts you act on. Alert-ignoring orgs run a museum of detections, not a defense.

← Firewalls: Packet, Stateful,...

WAF, Reverse Proxies & Content...